



KRYPTOGRAPHIE Teil3

M114 / ARJ / 6-2025

Die Themen:

- Symmetrische Verschlüsselung
Klassische Verfahren: ROT, Vigenere, XOR
Moderne Verfahren: AES
- Asymmetrische Verschlüsselung
Schlüsseltausch: Diffie-Hellman Schlüsseltausch
Verschlüsselung: RSA
- Digitale Signatur
Verfahren: RSA
Hashfunktion: MDx, SHAx
- Public Key Infrastruktur
Hierarchisch, X509-Zertifikate
Web-of-Trust, OpenPGP
- Sicheres Internet
HTTPS, TLS, Zertifikate
- Praxis: OpenPGP
gpg4win, Kleopatra
- Praxis: Sichere E-Mails
OpenPGP versus S-MIME, Mailclient Thunderbird

Die verwendeten Tools:

- Cryptool1
Lern-SW, Kryptographie Konzepte & Analyse
<https://www.cryptool.org/de/ct1>
- Wireshark
Network-Sniffer
Datenprotokolle: Analyse + grafische Aufbereitung
<https://www.wireshark.org>
- Gpg4win
Zertifikatsmanager Kleopatra
Dateiverschlüsselung Kleopatra
<https://www.gpg4win.de>
- Mozilla Thunderbird
Mail-Client
Unterstützt OpenPGP- und S/MIME-Zertifikate
<https://www.thunderbird.net/de>

**Bitte zeitnah auf ihren Notebook installieren.
Cryptool1 werden wir in Kürze einsetzen.**

Verschlüsselung in der Praxis:

PGP

Pretty Good Privacy

Phil Zimmermann, 1991

Hybrides Verfahren (Asym/Sym) IDEA, RSA

Web-of-Trust (keine zentrale Zertifizierungsstelle)

Nachricht signieren, verschlüsseln oder signieren und verschlüsseln
Kommerziell

OpenPGP

OpenPGP-Standard ab 1998

OpenSource

GnuPG

Implementierung vom OpenPGP-Standard

GNU-GPL

GPG4WIN

Implementierung vom OpenPGP-Standard

Persönliche OpenPGP-Schlüsselpaare (Dezentral, Web-of-Trust)

X.509-Schlüsselpaare (Zentrale Zertifizierungsinstanz)

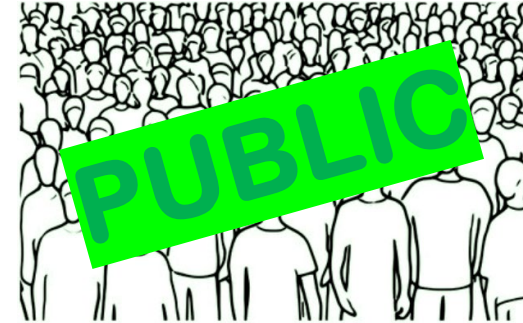
OpenPGP-Schlüssel und X.509-Schlüssel sind nicht kompatibel!

Das OpenPGP-Schlüsselpaar in Form von zwei ASCII-Dateien

Öffentlicher OpenPGP-Schlüssel

z.B. **FelixMusterPublic.asc**:

```
-----BEGIN PGP PUBLIC KEY BLOCK-----  
Version: GnuPG v2  
mHjzBFYjc.  
...  
-----END PGP PUBLIC KEY BLOCK-----
```



Privater OpenPGP-Schlüssel

z.B. **FelixMusterSecret.asc** :

```
-----BEGIN PGP PRIVATE KEY BLOCK-----  
Version: : GnuPG v2  
Wqdsf  
...  
-----END PGP PRIVATE KEY BLOCK-----
```



GPG4WIN und Kleopatra

Was möchten wir tun?

- Verschlüsseln
- Signieren
- Verschlüsseln und Signieren



GPG4WIN ist eine Free-Windows-Variante von GnuPG bzw. OpenPGP. *(PGP wäre die kommerzielle Variante.)*

GPG4WIN beinhaltet den GnuPG-Zertifikatsmanager **Kleopatra**.

Mit diesem kann man neue Schlüsselpaare erstellen und bestehende importieren und verwalten.

Im Weiteren ist es in Kleopatra möglich, Nachrichten zu verschlüsseln und/oder zu signieren.

Auftrag A "GPG4WIN/Kleopatra ein Schlüsselpaar erstellen" **Dauer: 8 Min.**

1. GPG4WIN auf dem Notebook installieren (<https://www.gpg4win.de/>)
2. Starten des gpg4win-Zertifikatsmanagers Kleopatra und Erzeugen eines persönlichen Schlüsselpaars unter Datei/Neues OpenPGP-Schlüsselpaar...

(Hinweis: Alternativ wäre auch ein X.509-Schlüsselpaar denkbar. Dazu müsste man aber eine Beglaubigungsstelle einbeziehen, was den Rahmen dieser Übung sprengen würde.)

Beim Erzeugen eines Schlüsselpaars wird eine sogenannte Passphrase verlangt. Dies ist ein Passwort, dass man später beim Erstellen und Öffnen einer verschlüsselten Nachricht eingeben muss. Diese Passphrase darf man darum keinesfalls vergessen und niemals weitergeben.

3. Exportieren des eigenen öffentlichen Schlüssels. Achtung: Hier den PublicKey und nicht den PrivateKey exportieren! Im Zweifelsfall mit einem Texteditor der Wahl das ASC-File überprüfen! *(In der ersten Zeile sollte BEGIN PGP PUBLIC KEY BLOCK stehen.)* Der PublicKey sollte etwa so benannt sein: Vorname_Nachname_PublicKey.asc
4. Importieren sie in Kleopatra die öffentlichen Schlüssel ihrer Kommunikationspartner.

(Hinweis zu den Schlüsseln: Sowohl öffentliche wie auch geheime Schlüssel können in Kleopatra importiert oder exportiert werden. Beide Schlüssel haben die Dateiendung .asc. Dies ist ein Hinweis, dass es sich um ASCII-Dateien handelt, die mit einem Texteditor wie z.B. Notepad++ geöffnet werden können. Damit lässt sich zumindest feststellen, ob die betreffende Datei PrivateKey oder PublicKey ist. Welcher Person diese zuzuordnen ist, bleibt innerhalb der Datei allerdings verborgen. Darum empfiehlt es sich, dem Dateinamen Sorge zu tragen, weil er der einzige Hinweis auf den Besitzer ist.)



Auftrag B "GPG4WIN/Kleopatra anwenden" **Dauer: 20 Min.**

1. **Nachricht verschlüsseln:**

Es soll eine Datei (Nachricht als Text, Bild etc.) für ihren Kommunikationspartner verschlüsselt werden. Dies kann direkt in Kleopatra erfolgen. Stellen sie das verschlüsselte File ihrem Kommunikationspartner zur Verfügung. Wenn dieser es entschlüsseln kann, wurde der Auftrag erfolgreich erledigt.

2. **Nachricht signieren:**

Nun soll eine Datei für ihren Kommunikationspartner signiert werden. Dies kann ebenfalls wieder direkt in Kleopatra erfolgen. Stellen sie das File inklusive Signatur ihrem Kommunikationspartner zur Verfügung. Wenn dieser mit der Signatur die Echtheit ihres Files verifizieren kann, wurde der Auftrag erfolgreich erledigt.

3. **Nachricht verschlüsseln und signieren:**

Diesmal soll eine Datei für ihren Kommunikationspartner verschlüsselt und signiert werden. Wiederum in Kleopatra. Stellen sie das File inklusive Signatur ihrem Kommunikationspartner zur Verfügung. Wenn dieser das File entschlüsseln und dank der Signatur den Absender verifizieren kann, wurde der Auftrag erfolgreich erledigt.

Zusatzfrage: Welchen Mehrwert hat das Verschlüsseln mit zusätzlichem Signieren?

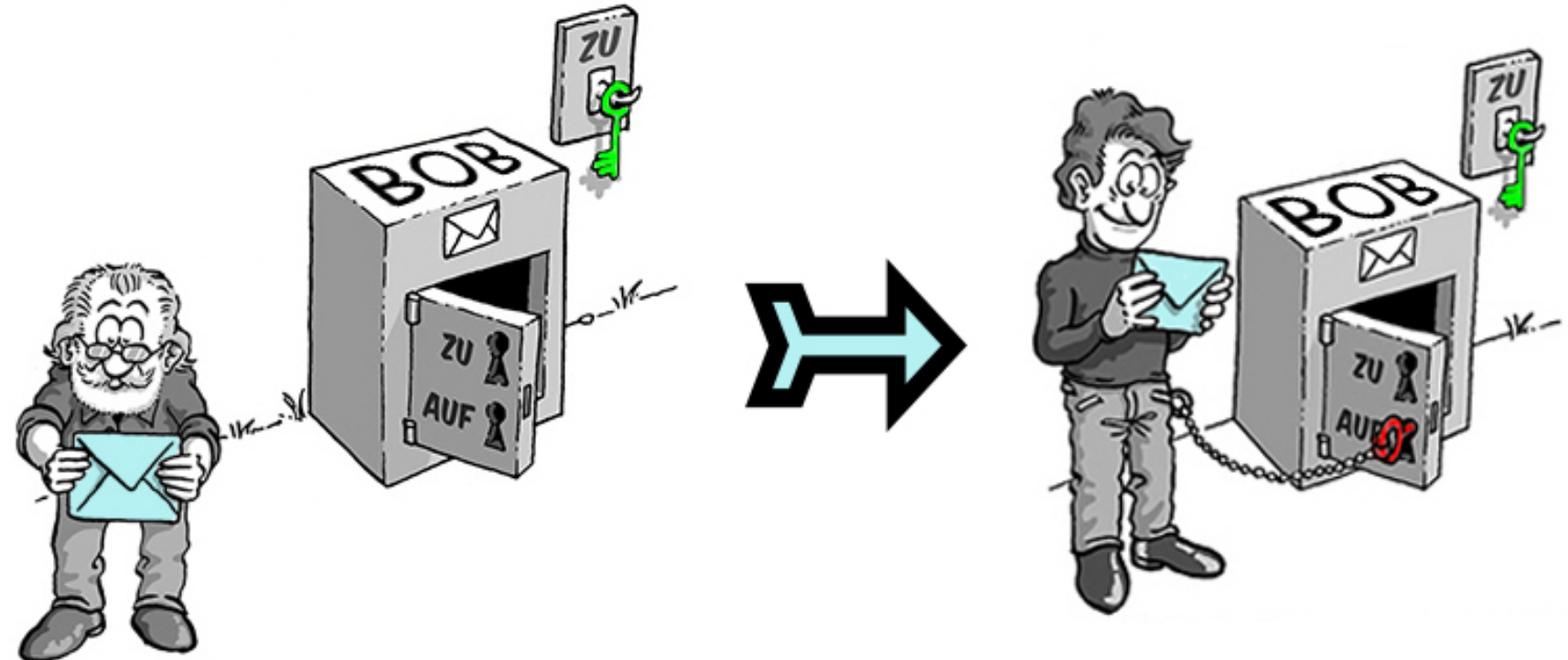


Asymmetrische Verschlüsselung

PublicKey von wem?



Ist dies der
"Public-Key
Händler"
ihres
Vertrauens?

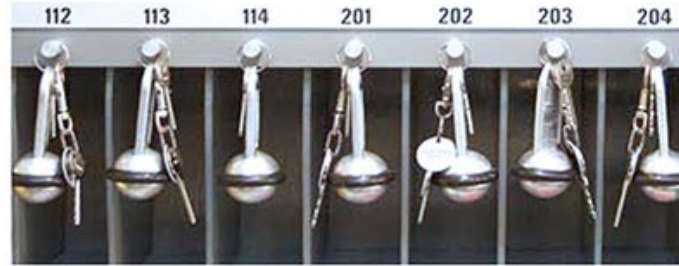


Asymmetrische Verschlüsselung

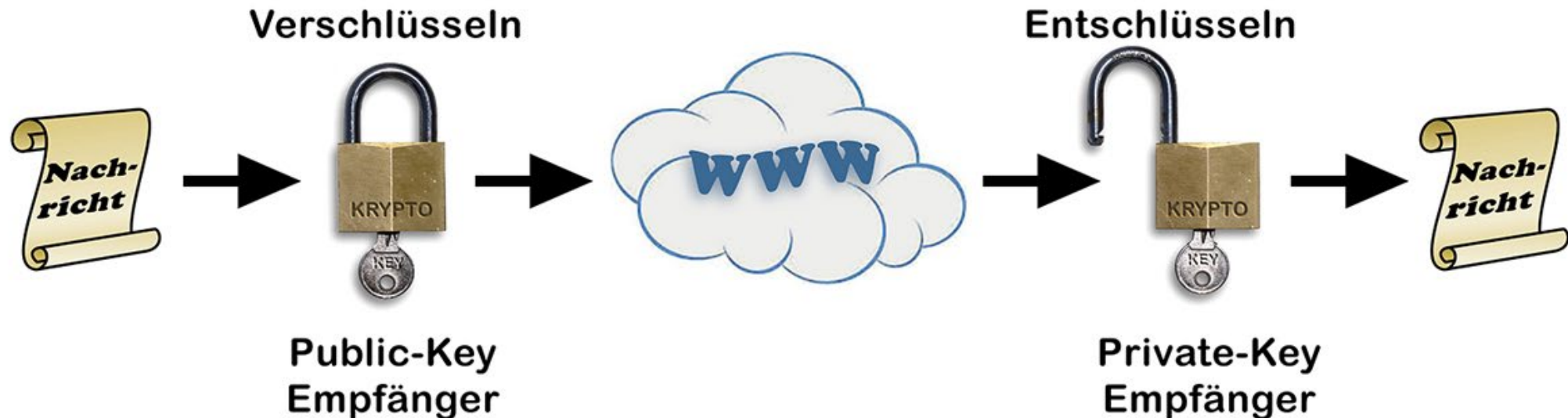
Wohin also
mit dem
Public-Key?



Schlüsselpaar
erzeugen



Public-Key veröffentlichen
Private-Key geheim halten

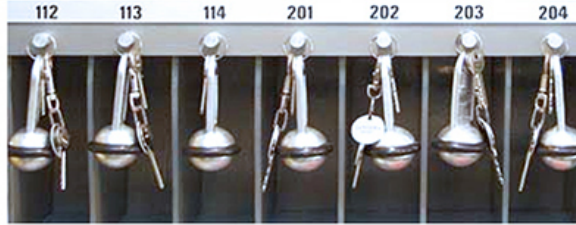


Asymmetrisches Verfahren: Digitale Signatur

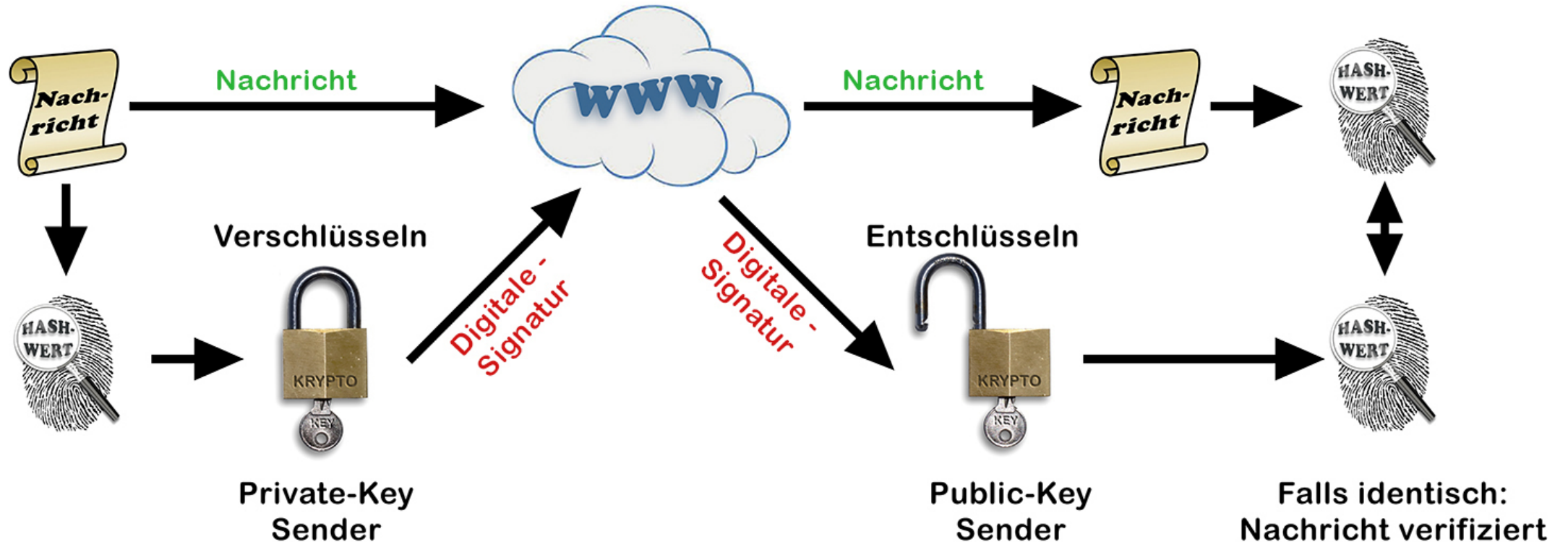
Wohin also
mit dem
Public-Key?



Schlüsselpaar
erzeugen



Public-Key veröffentlichen
Private-Key geheim halten





Lösungsvariante 1



Web of Trust



OpenPGP



Offenbar ist dieser
nette Herr doch nicht der
"Public-Key Händler"
ihres Vertrauens!

Lösungsvariante 2



Public-Key-Infrastruktur



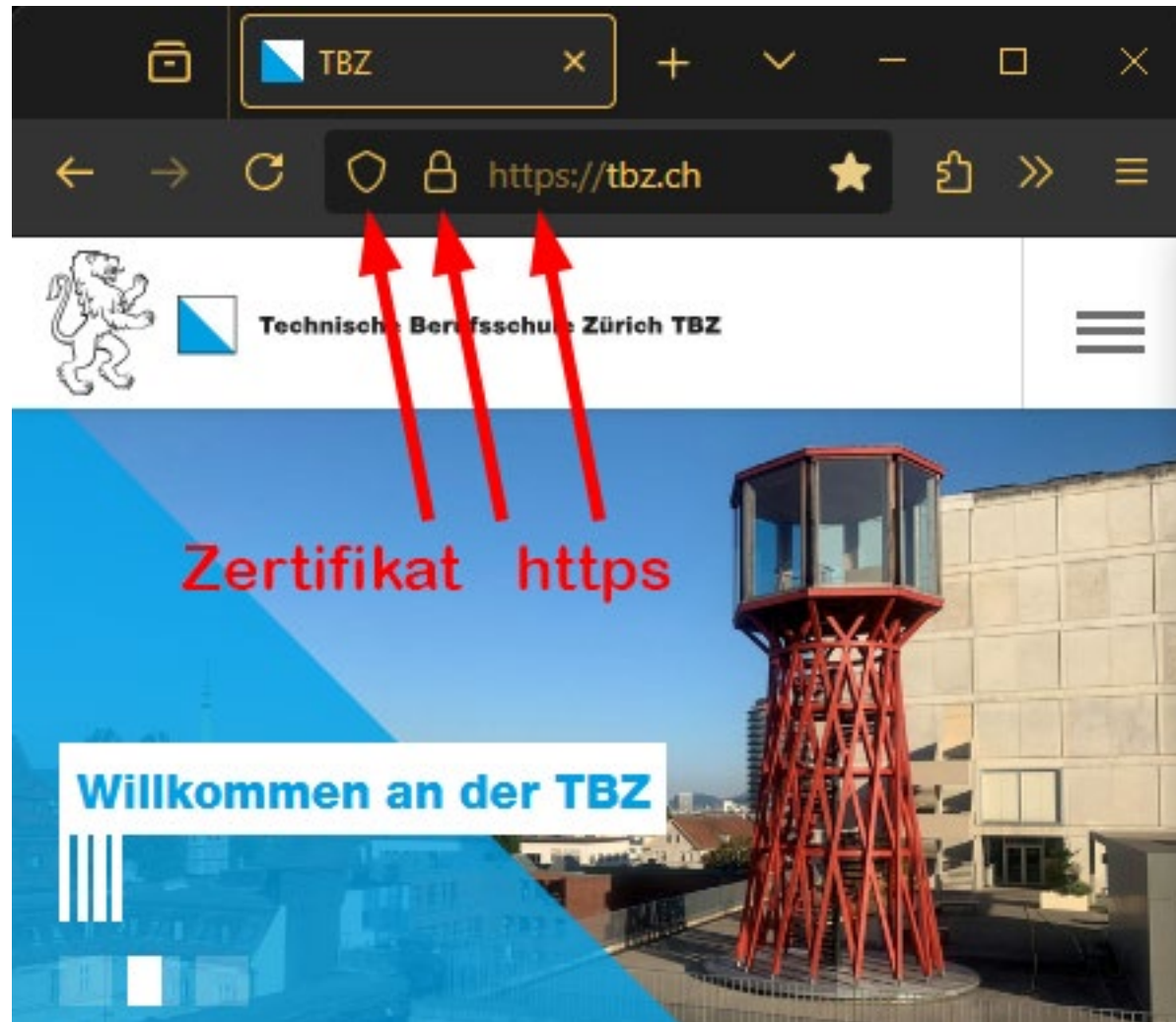
X.509

X.509 ist ein Standard für eine PKI zum Erstellen von digitalen Zertifikaten.

PKI - Public-Key-Infrastruktur-Begriffe:

- **PKI** stellt digitale Zertifikate aus
- Zertifizierungsstelle (Certificate Authority, **CA**)
- Registrierungsstelle (Registration Authority, **RA**)
- Zertifikatsperrliste (Certificate Revocation List, **CRL**)
- Verzeichnisdienst (Directory Service)
- Validierungsdienst (Validation Authority, **VA**)
- Dokumentationen: **CP** (Certificate Policy), **CPS** (Certification Practice Statement), **DS** (Policy Disclosure Statement)
- Subscriber: Inhaber von Zertifikaten
- Participant: Nutzer von Zertifikaten

Sicherheit im Internet mit Kryptografie und Zertifikaten



OSI-Layer TCP/IP-Stack

Kopplung

Upper-Layers
Anwendungs-
orientiert

7	Application Anwendung	Anwendung Dienste (Protokolle) HTTP / HTTPS FTP SMTP POP DNS NFS SMB etc.	Daten	Gateway Proxy
	6 Presentation Darstellung			
	5 Session Sitzung			
4	Transport Transport Port #	Transport TCP (verbindungsorientiert) UDP (verbindungslos)	Segmente Datagramme TLS Transport Layer Security	Router L3-Switch
3	Network Vermittlung IP #	Internet (verbindungslos) IP, IPsec, ICMP	Pakete max. 64 kByte	
2	Data-Link Sicherung VLAN # MAC #	Netzzugang Ethernet, MAC	Rahmen, Frame max. 1518 Byte oder 1522 Byte mit VLAN-Tag 9000 Byte Jumboframe	Bridge, Switch WLAN-AP
1	Physical Bitübertragung		Bit's Symbole	Netzwerkkabel Repeater, Hub

End
to
End
Multihop

End
to
End
Multihop

Point
to
Point

Point
to
Point

Mindestanforderungen für Validierungsmethoden:

- **Domain Validated: (0-\$)** Nachweis der Kontrolle über die Domain via DNS, HTTP, E-Mail.
- **Individual Validated: (\$\$)** Zusätzlich überprüfte Identität des Antragstellers im Zertifikat.
- **Organization Validated: (\$\$\$)** Zusätzlich amtlich bestätigter Firmennamen.
- **Extended Validation: (\$\$\$\$)** Strengste Prüfkriterien bezüglich Identität, Geschäftsadresse, Domainbesitz. Antragssteller unterschreibt rechtlich bindende Dokumente als zeichnungsberechtigter Firmenvertreter. Überprüfte Zertifizierungsstelle erforderlich.

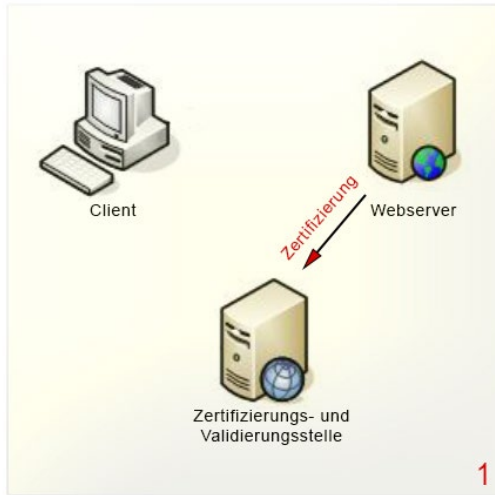
Klassifizierung der E-Mail-Zertifikate von Anbietern sicherer E-Mail-Kommunikation:

1. Echtheit der E-Mail-Adresse wird durch Zertifizierungsstelle bestätigt.
2. Zusätzlich wird der dazugehörige Name ggf. Organisation/Firma in das Zertifikat mit aufgenommen.
3. Verifizierung der Angaben mithilfe Drittdatenbanken, Ausweiskopien, Handelsregistrauszügen etc.
4. Antragsteller muss sich zusätzlich persönlich ausweisen.

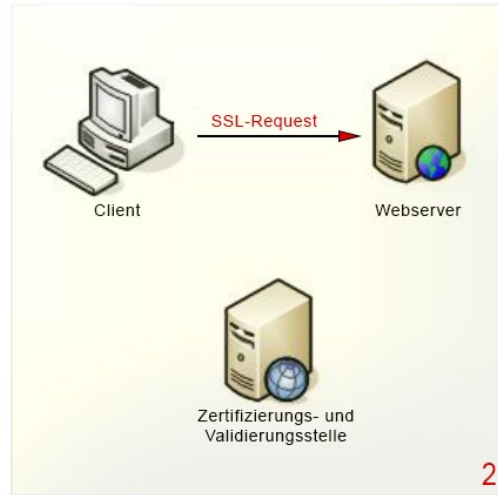
Auswahl:

- **Letsencrypt:** Kostenlos, Domain validiertes Zertifikat <https://letsencrypt.org/de/https://letsencrypt.org/de/how-it-works/>
- **CaCert:** Nichtkommerziell, kostenfreie X.509-Zertifikate <http://www.cacert.org/>
- **Verisign:** Kommerziell, USA <https://www.verisign.com/>
- **Globalsign:** Kommerziell, Japan <https://www.globalsign.com/en>
- **DigiCert/Quovadisglobal:** Kommerziell, Schweiz <https://www.quovadisglobal.com/ch/>
- **Swisssign:** Kommerziell, Schweiz <https://www.swisssign.com/>

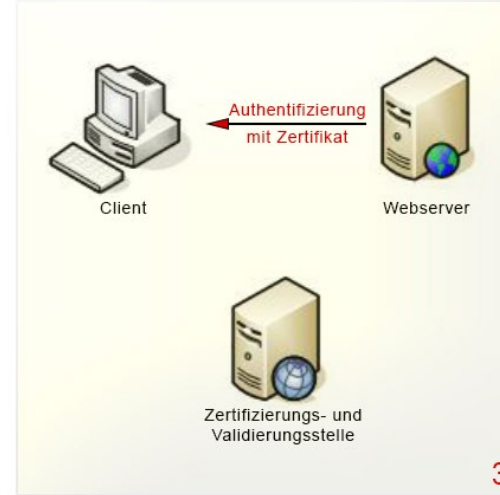
TLS-Handshake mit Schlüsselaustausch



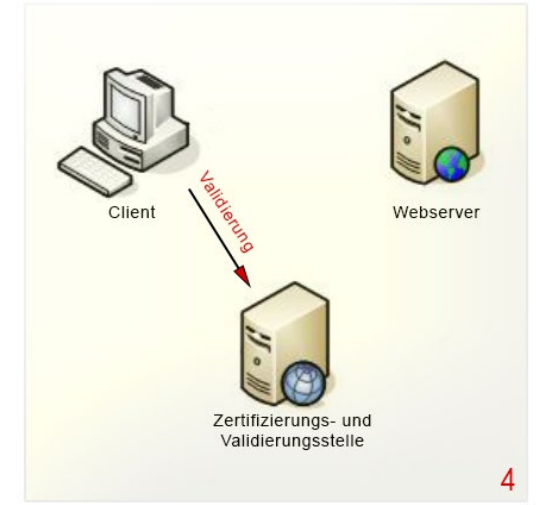
Webserver lässt sich von einer Zertifizierungsstelle ein Zertifikat ausstellen



Webbrowser möchte eine HTTPS-Webseite aufrufen und verlangt das Zertifikat des Webserver.



Webbrowser erhält vom Webserver das Zertifikat.



Webbrowser lässt sich das erhaltene Zertifikat bei der Zertifizierungsstelle auf seine Gültigkeit überprüfen.

Untersuchen wir nun ein paar Webseiten:

- <http://www.example.com>
- <https://www.zkb.ch>
- <https://www.tbz.ch>

Was sagt der Browser zum Zertifikat?

Was zeigt uns Wireshark?



Wireshark ist hier erhältlich:

<https://www.wireshark.org/>

Achtung: Wireshark ist ein Sniffer-Tool.
Für die Verwendung am Arbeitsplatz bitte zuerst
bei ihrem Boss um Erlaubnis bitten.

Wireshark-Displayfilter:

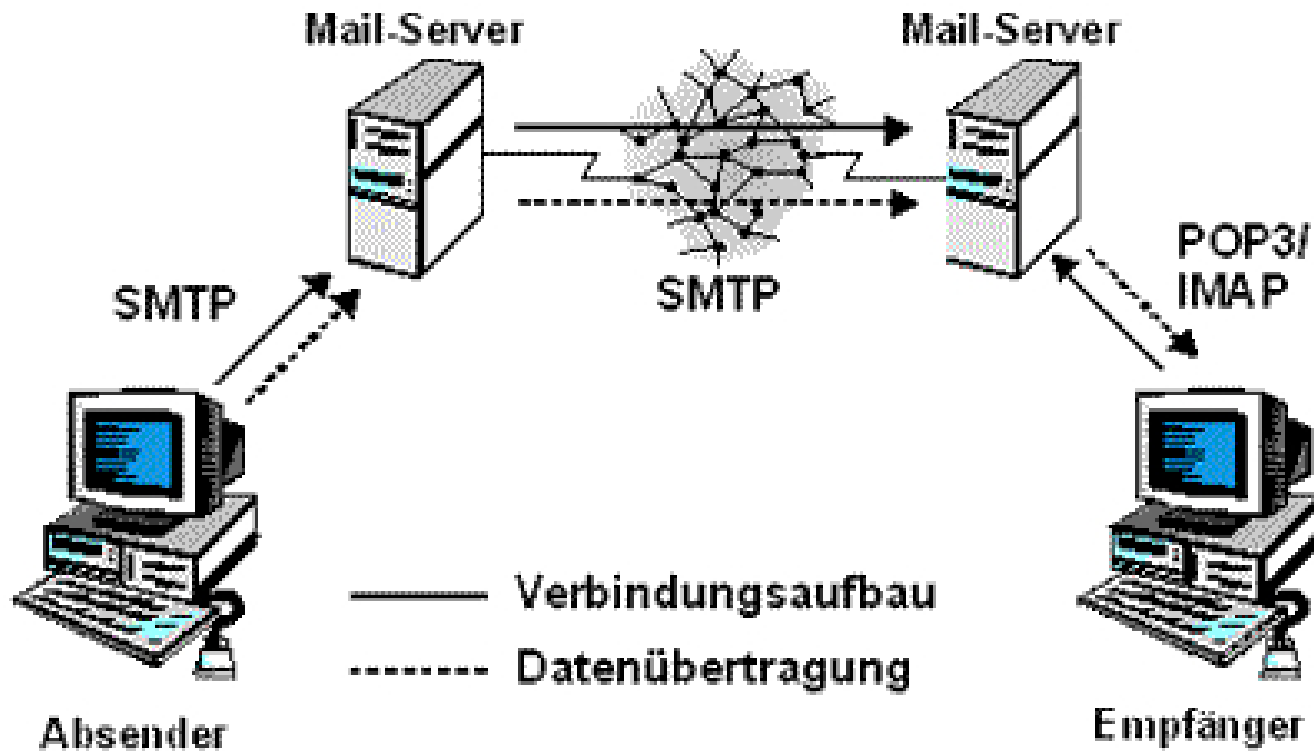
`ssl.handshake.extensions_server_name` *Zeigt alle Client Hello HTTPS*

`tcp.port eq 80 && http` *Zeigt alle HTTP-Anfragen auf Port 80*

**Sichere eMails
mit dem Opensource
Mailclient
THUNDERBIRD**



Zuvor etwas "graue Theorie" zu eMail



Zugangsdaten:

- Username/Passwort
- SMTP-Ausgangsserver
- SMTP-Port-Nr.
- POP3-Eingangsserver
- POP3-Port-Nr.

Oder:

- IMAP-Eingangsserver
- IMAP-Port-Nr.

Kennwerte für den TBZ-EMail-Account `vorname.name@edu.tbz.ch`

Stand: 2024

	Posteingang POP ^{1.)}	Posteingang IMAP ^{2.)}	Postausgang SMTP ^{3.)}
Servername	outlook.office365.com	outlook.office365.com	smtp.office365.com
Portnummer	995	993	587
Verschlüsselung	TLS	TLS	STARTTLS

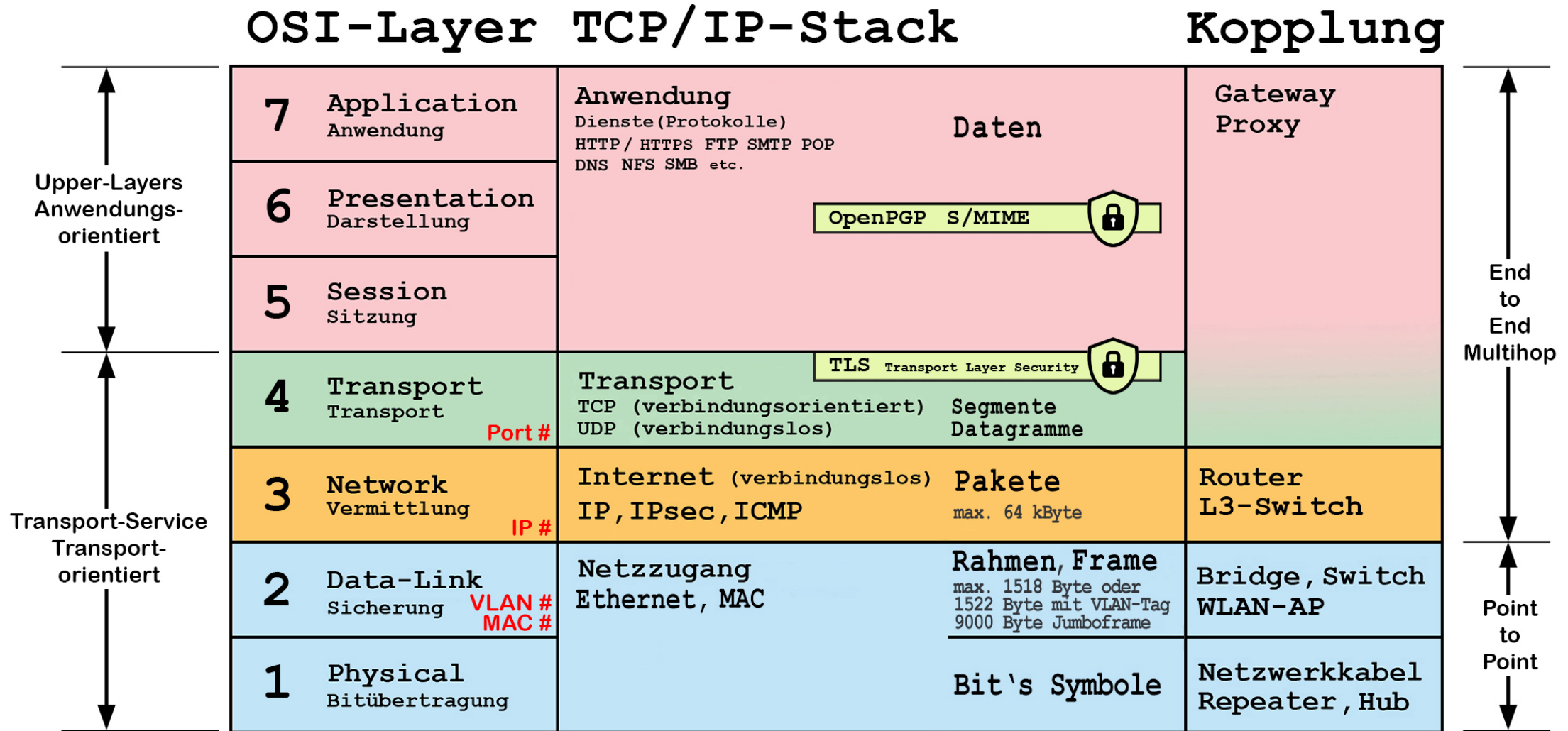
- 1.) Die E-Mail-Nachrichten werden nach dem Abrufen auf dem E-Mail-Server gelöscht.
- 2.) Die E-Mail-Nachrichten werden zwischen E-Mail-Client und E-Mail-Server synchronisiert.
- 3.) Die E-Mail-Nachrichten werden über dieses Protokoll versendet.

Einrichtebeispiel für Outlook

Authentifizierungsmethode: OAuth2

	Server-Adresse	Port	Verschlüsselung	Authentifizierung	Benutzername
Posteingang IMAP	outlook.office365.com	993	TLS	Passwort, Normal	E-Mail-Adresse
Postausgang SMTP	smtp.office365.com	587	STARTSSL	Passwort, Normal	E-Mail-Adresse

TLS versus Email-Verschlüsselung im OSI-Schichtenmodell



Auftrag "Den Mailclient Thunderbird installieren und einrichten" **Dauer: 40 Min.**

1. Installieren sie den eMail-Client "Mozilla Thunderbird". Siehe <https://www.thunderbird.net/de/>
2. Richten sie ihr eMail-Konto darin ein.
Es wird empfohlen, nicht ihr produktiver eMail-Account zu verwenden, sondern ein explizit für Tests eingerichteten.
3. Überprüfen sie ihre Thundebord-Installation bzw. Konfiguration, indem sie gegenseitig **unverschlüsselte eMails** austauschen.
4. Nun widmen wir uns der Ende-zu-Ende Verschlüsselung: Erzeugen sie sich ein OpenPGP-Schlüsselpaar.
(Hinweis: Ihr OpenPGP-Schlüsselpaar, das sie in Kleopatra kreiert haben, könnte hier auch verwendet werden.)
5. Tauschen sie die PublicKeys gegenseitig aus.
6. Nun geht es an den eMail-Austausch: Schicken sie ihrem Kommunikationspartner/in verschlüsselte und/oder signierte eMails.
7. Zur Kontrolle schicken sie eine verschlüsselte eMail an edu@juergarnold.ch
(Hinweis: Den hierfür benötigte PublicKey finden sie hier: https://edu.juergarnold.ch/Thunderbird_PK_ARJ.zip)
8. Erstellen sie eine Kurzanleitung, die ihre Installationsschritte bechreibt und geben sie diese auf Teams/Aufgabe der Lehrperson ab. In ihre Kurzanleitung muss die Thunderbird-Versionsnummer erwähnt sein, auf die sich ihre Arbeitsschritte beziehen.

